

INCIDENT RESPONSE REPORT

PrintNightmare Exploitation (CVE-2021-34527)

Vulnerability: CVE-2021-34527 (PrintNightmare)	Severity: CRITICAL
Target Host: DESKTOP-MDI1F3E	Status: Contained & Remediated
Domain: mydomain.com (Active Directory)	

1. Executive Summary

During automated threat monitoring, Splunk SIEM identified high-fidelity alert sequences indicating active exploitation of CVE-2021-34527 (PrintNightmare) against a domain-joined Windows 10 workstation (DESKTOP-MDI1F3E) within the mydomain.com Active Directory environment. An unauthorized DLL payload was staged into the Windows spool driver directory, loaded into spoolsv.exe under NT AUTHORITY\SYSTEM privileges, and leveraged to spawn an administrative shell (cmd.exe). Detection rules triggered, enabling rapid containment, machine isolation, and service hardening.

2. Attack Chain & Telemetry Analysis

The complete attack lifecycle was correlated across Sysmon and Windows Security Event Logs ingested into Splunk:

Stage	Activity	Source Log	Event ID	Key Telemetry Field
1. Payload Staging	Malicious DLL written to driver staging path	Sysmon Operational	11	TargetFilename: \spool\prtprocs\x64*
2. Module Load	Unsigned DLL loaded into Print Spooler process	Sysmon Operational	7	Image: spoolsv.exe, Signed: false
3. Privilege Escalation	Spooler spawned elevated cmd.exe shell	Sysmon / Win Security	1 / 4688	ParentImage: spoolsv.exe -> Image: cmd.exe

3. Detection Engineering (Splunk SPL Queries)

Query 1: Abnormal Process Spawning

Detects interactive shell executions spawned directly by spoolsv.exe:

```
index=sysmon EventCode=1
| eval ParentImage=lower(ParentImage)
| eval Image=lower(Image)
| where like(ParentImage, "%spoolsv.exe")
      AND (like(Image, "%cmd.exe")
           OR like(Image, "%powershell.exe")
           OR like(Image, "%wscript.exe")
           OR like(Image, "%cscript.exe")
           OR like(Image, "%rundll32.exe")
           OR like(Image, "%regsvr32.exe"))
```

```
OR like(Image, "%mshta.exe")
OR like(Image, "%whoami.exe")
OR like(Image, "%net.exe"))
| table _time, Computer, User, Image, ParentImage, CommandLine, Hashes
| sort - _time
```

Query 2: Unsigned DLL Loaded by Print Spooler

Flags unsigned driver modules loaded into the Spooler service context:

```
index=sysmon EventCode=7
| eval Image=lower(Image)
| where like(Image, "%spoolsv.exe")
      AND (Signed="false" OR Signed="")
| table _time, Computer, Image, ImageLoaded, Signed, SignatureStatus, Hashes
| sort - _time
```

Query 3: Malicious Print Processor Registry Registration

Monitors persistence attempts via Print Processor registry keys:

```
index=sysmon EventCode=11
| where like(lower(TargetFilename), "%\\spool\\drivers\\%")
      AND like(lower(TargetFilename), "%.dll")
| table _time, Computer, Image, TargetFilename, CreationUtcTime
| sort - _time
```

4. Containment & Remediation Actions

Immediate Containment Steps

- **Host Isolation:** Isolated DESKTOP-MDI1F3E from the network adapter level to block potential lateral movement.
- **Account & Process Neutralization:** Stopped the Spooler service and removed rogue accounts via PowerShell:

```
Stop-Service -Name Spooler -Force
Set-Service -Name Spooler -StartupType Disabled
Remove-LocalUser -Name "backdoor"
```

Long-Term Hardening & Mitigation

1. **Patch Management:** Applied Microsoft KB5004945 update across all domain endpoints.
2. **Point and Print Restriction:** Enforced administrator-only printer driver installation via registry policy:

```
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers\PointAndPrint" \
/v RestrictDriverInstallationToAdministrators /t REG_DWORD /d 1 /f
```

3. **Domain Controller Hardening:** Disabled Print Spooler service on all Domain Controllers via GPO.